



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

Tarea 3

Identificación de los riesgos Data Center

Autor (es):

Alvarado López, Brizeth Jazmin - balvaradol3@miumg.edu.gt

Samayoa Girón, Miguel Estuardo- msamayoag9@miumg.edu.gt

Franco Recinos, Katerine Jireh - kfrancor2@miumg.edu.gt

Ajset Nimacaché, Edgar Fernando - eajsetn@miumg.edu.gt

Profesor

BLANCO ACEVEDO, ERICK ENRIQUE

Curso

Gobierno Riesgo y Cumplimiento – II Trimestre - 2026

Guatemala, 2026

Índice

Introducción.....	3
Desarrollo.....	5
1. Alcance Técnico y Descripción Institucional.....	5
1.1. Criterios de Evaluación de Riesgos (Acuerdo A-028-2021).....	5
2. Desarrollo de las Matrices A-028-2021.....	6
2.1. Identificación de Riesgos.....	6
3. Integración Estructural de Normas ISO/IEC 27000.....	7
4. Análisis de Gobierno, Riesgo y Cumplimiento (GRC).....	9
4.1. Síntesis del Análisis GRC Aplicado.....	10
Conclusiones.....	11

Introducción

En el presente trabajo se analiza el caso de la Empresa Municipal de Servicios Ciudadanos (EMSC), una entidad pública, creada para el desarrollo de dicha actividad académica. El proceso principal de la EMSC es la gestión de pagos y trámites municipales en línea, ya que a través de este proceso se atiende a los ciudadanos mediante plataformas digitales que permiten realizar pagos, consultas, validaciones y solicitudes de servicios administrativos. Este proceso es crítico porque depende de la disponibilidad permanente del sistema, de la integridad de la información procesada y de la confidencialidad de los datos almacenados. Además, al tratarse de una plataforma transaccional, cualquier interrupción, manipulación no autorizada o pérdida de información puede afectar directamente tanto a la institución como a los ciudadanos.

Dentro de este proceso existen varios activos críticos de información y tecnológicos que deben ser protegidos. Entre ellos destaca, en primer lugar, la base de datos de ciudadanos, ya que contiene información sensible como nombres, direcciones, números de identificación, historial de pagos, registros administrativos y otros datos personales. También es fundamental el servidor transaccional, debido a que ahí se ejecuta el sistema principal que procesa los pagos y los trámites. Otro activo relevante son las credenciales de acceso, pues permiten el ingreso de usuarios, administradores y operadores al sistema, por lo que una mala gestión de estas podría derivar en accesos no autorizados. Asimismo, forman parte de los activos críticos los respaldos o copias de seguridad, el firewall, los enlaces de comunicación, la integración bancaria para procesar pagos y la infraestructura en la nube, utilizada para almacenamiento, respaldo o continuidad operativa. Todos estos elementos sostienen la operación del servicio y, por lo tanto, deben ser considerados dentro del análisis de riesgos.

En relación con las amenazas posibles, la EMSC enfrenta riesgos comunes en entornos tecnológicos y de data center. Entre ellos se encuentra el ransomware, que podría cifrar la información y dejar inoperable la plataforma; la fuga de información, que comprometería la confidencialidad de los datos personales y financieros de los ciudadanos; la caída del sistema, que afectaría la continuidad del servicio; los errores humanos, que pueden provocar eliminaciones, configuraciones incorrectas o fallos operativos; y los accesos no autorizados, que pondrían en riesgo la integridad y confidencialidad de la información. De igual forma, deben considerarse riesgos asociados a la falla del proveedor cloud, así como las fallas de terceros, especialmente porque el sistema depende de integraciones externas, como

entidades bancarias u otros servicios tecnológicos. Estas amenazas justifican la necesidad de contar con una gestión de riesgos estructurada y alineada con buenas prácticas internacionales.

Para sustentar el análisis, se propone integrar el caso con las normas ISO clave de la familia 27000, en concordancia con lo que exige la guía del curso. En este trabajo se utilizarán como referencia la ISO/IEC 27005, para la identificación, análisis y tratamiento de riesgos; la ISO/IEC 27002, para la definición de controles de seguridad; la ISO/IEC 27004, para indicadores y métricas; la ISO/IEC 27007, para auditoría de controles; la ISO/IEC 27008, para la evaluación de controles de seguridad; la ISO/IEC 27014, para el enfoque de gobernanza; la ISO/IEC 27017, para controles asociados a servicios en la nube; la ISO/IEC 27018, para la protección de datos personales en entornos cloud; y la ISO/IEC TR 27016, para el análisis del valor económico de la seguridad. Estas normas aparecen expresamente señaladas en la guía como parte de la integración esperada del trabajo.

En consecuencia, el caso de la EMSC resulta adecuado para el desarrollo de las matrices del Acuerdo A-028-2021, ya que permite identificar procesos, activos, amenazas, vulnerabilidades, controles, métricas, criterios de auditoría y decisiones estratégicas desde un enfoque de Gobierno, Riesgo y Cumplimiento (GRC). Además, facilita que el análisis no se limite únicamente a aspectos técnicos, sino que incorpore también la definición de responsables, la toma de decisiones, la supervisión institucional y el cumplimiento de normas y buenas prácticas. De esta manera, el caso proporciona una base coherente y suficientemente completa para el trabajo del subequipo encargado de las matrices y del subequipo responsable del análisis GRC.

Desarrollo

1. Alcance Técnico y Descripción Institucional

La Empresa Municipal de Servicios Ciudadanos (EMSC) se constituye como una entidad de derecho público cuya responsabilidad misional es la administración, recaudación y gestión ininterrumpida de los servicios y trámites municipales. Esta operación se ejecuta a través de una plataforma transaccional crítica, diseñada para procesar en tiempo real los pagos de arbitrios y la emisión de licencias, gestionando de forma simultánea grandes volúmenes de Información de Identificación Personal (PII) y datos financieros. Para soportar esta carga operativa y mantener la disponibilidad de los servicios frente a la demanda ciudadana, la institución ha desplegado una arquitectura tecnológica híbrida.

El alcance técnico del presente análisis de riesgos se concentra en evaluar la totalidad de esta infraestructura híbrida, abarcando tanto los componentes físicos y lógicos del Data Center institucional localizado en las instalaciones de la municipalidad (On-Premise), como los servicios descentralizados de infraestructura como código (IaaS) y almacenamiento en la nube pública, utilizados primordialmente para la ejecución de copias de seguridad inmutables y la habilitación de los planes de continuidad del negocio (BCP). El objetivo primordial de esta evaluación integral es identificar y mitigar de forma proactiva los vectores de ataque inherentes a las arquitecturas híbridas, minimizando la superficie de exposición y garantizando la resiliencia operativa de los servicios de recaudación frente a fallos catastróficos, ya sean originados por fallas en la infraestructura física, errores de configuración lógica o amenazas cibernéticas avanzadas.

1.1. Criterios de Evaluación de Riesgos (Acuerdo A-028-2021)

Con el propósito de asegurar la homogeneidad, trazabilidad y objetividad en el proceso de evaluación dentro de las matrices de gestión, y en estricto cumplimiento con los lineamientos del Sistema Nacional de Control Interno Gubernamental (SINACIG) estipulados en el Acuerdo A-028-2021, se ha definido un marco de valoración institucional estandarizado. Este marco permite cuantificar el nivel de exposición de los activos tecnológicos mediante una escala paramétrica estructurada en dos dimensiones fundamentales:

Para la dimensión de Probabilidad, se establece una escala de estimación de 1 a 5, basada en la frecuencia proyectada de materialización de la amenaza. Esta escala inicia en el

nivel 1, considerado "Muy improbable", para aquellos eventos anómalos cuya recurrencia histórica o proyectada es superior a los cinco años. La valoración escala progresivamente hasta alcanzar el nivel 5, catalogado como "Muy probable", reservado para aquellos incidentes o vulnerabilidades activas cuya manifestación se espera con una frecuencia mensual o incluso superior, representando una amenaza constante para la operación.

Respecto a la dimensión de Impacto, se emplea de igual forma una escala del 1 al 5, orientada a medir el grado de afectación sobre la operatividad del negocio, la confidencialidad de la información y la reputación institucional. El nivel 1, definido como "Insignificante", agrupa aquellos eventos que no generan interrupción perceptible en los servicios de atención al ciudadano. Por el contrario, la escala culmina en el nivel 5, clasificado como "Catastrófico", el cual se asigna a incidentes críticos que provocan una caída total de los sistemas transaccionales superior a las veinticuatro horas, o que resultan en la exfiltración masiva, pérdida irreversible o alteración no autorizada de los datos financieros y personales (PII) custodiados por la municipalidad.

2. Desarrollo de las Matrices A-028-2021

El desarrollo técnico de la gestión de riesgos se materializa en el archivo adjunto, el cual sistematiza el ciclo de vida de la seguridad mediante las doce matrices exigidas por el Acuerdo A-028-2021 (SINACIG). Esta sección detalla los hallazgos consignados en las hojas de Identificación de Procesos (Hoja 1) y Identificación de Riesgos (Hoja 2), garantizando que cada escenario esté vinculado a un activo crítico y una vulnerabilidad explotable, bajo los lineamientos metodológicos de ISO/IEC 27005.

2.1. Identificación de Riesgos

En cumplimiento con la normativa, la identificación se centró en los riesgos que impactan directamente el proceso de gestión de pagos y trámites municipales. El enfoque metodológico establece que el riesgo surge cuando una vulnerabilidad técnica o administrativa es aprovechada por una amenaza para comprometer un activo de información. Para el caso de la EMSC, se han priorizado cinco escenarios críticos que abarcan las dimensiones lógicas, operativas y legales del sistema transaccional.

En la dimensión de seguridad informática, se identifican dos vectores críticos relacionados con el acceso y la integridad de los datos. El primer riesgo (R-01) corresponde a la amenaza de Ransomware sobre la base de datos transaccional, cuya vulnerabilidad es la

falta de aplicación de parches críticos en el sistema operativo. Complementariamente, se identifica el riesgo de acceso no autorizado (R-03) a los portales ciudadanos, provocado por una política de autenticación débil basada únicamente en credenciales básicas, sin el despliegue de factores múltiples (MFA). Estos hallazgos exigen el fortalecimiento de los controles lógicos para evitar el secuestro o la manipulación de la información ciudadana.

Desde la perspectiva de continuidad operativa, el análisis documentado en las matrices aborda la disponibilidad del servicio frente a picos de demanda y fallos de infraestructura híbrida. Se registra el riesgo de caída del sistema (R-04) debido a una capacidad de procesamiento limitada frente a incrementos masivos en la demanda de pagos a fin de mes, lo que satura el servidor transaccional. Asimismo, se identifica la falla del proveedor cloud (R-02) como una amenaza a la resiliencia operativa, cuya vulnerabilidad radica en la ausencia de acuerdos de nivel de servicio (SLA) formalmente definidos que garanticen la restauración oportuna de los respaldos.

Finalmente, en la dimensión de cumplimiento legal, se identifica el riesgo de fuga de información (R-05) que afecta directamente la confidencialidad de los datos de los ciudadanos. La vulnerabilidad crítica es la ausencia de cifrado de datos tanto en reposo como en tránsito, lo que expone a la institución a sanciones severas y multas legales por incumplimiento de normativas de protección de datos personales. Este enfoque integral permite que las matrices de mitigación y evaluación económica se fundamenten en datos técnicos precisos y riesgos reales documentados en la herramienta de gestión.

3. Integración Estructural de Normas ISO/IEC 27000

La integración estratégica de la familia de normas ISO/IEC 27000 es el pilar fundamental que eleva el presente modelo de gestión de riesgos. Mientras que las matrices del Acuerdo A-028-2021 (SINACIG) proveen la estructura administrativa para inventariar, analizar y dar seguimiento a los riesgos institucionales, son las normativas ISO las que aportan el rigor técnico, metodológico y justificativo. Esta convergencia permite que el manejo de amenazas no se limite a un ejercicio burocrático, sino que se convierte en una arquitectura de seguridad robusta y alineada con buenas prácticas internacionales, dotando de contexto y solidez a la protección de los sistemas transaccionales de la entidad.

El núcleo de esta arquitectura recae en la ISO/IEC 27005, la cual funciona como el marco de referencia metodológico principal para la identificación, análisis y valoración de los

riesgos. Esta norma estructura sistemáticamente el proceso para descubrir cómo vulnerabilidades específicas pueden ser explotadas por amenazas y cuantificar el impacto potencial sobre los activos críticos. Para abordar de manera efectiva los niveles de riesgo identificados, la ISO/IEC 27002 proporciona el catálogo técnico de salvaguardas, guiando la selección e implementación de controles físicos, lógicos y perimetrales diseñados para reducir la superficie de ataque frente a accesos no autorizados, fallos de configuración y ataques que comprometen la disponibilidad del servicio de recaudación municipal.

En el contexto específico de una infraestructura tecnológica híbrida, la extensión de los perímetros de seguridad resulta imperativa. La ISO/IEC 27017 interviene para establecer los controles específicos requeridos para gestionar la seguridad en los entornos y servicios cloud utilizados como respaldo y continuidad. De manera paralela e indisoluble, la ISO/IEC 27018 dicta los lineamientos rigurosos para la protección de la Información de Identificación Personal (PII) ciudadana almacenada o procesada en estas plataformas en la nube, garantizando el cumplimiento de los estándares de privacidad frente a posibles brechas de datos.

La validación técnica y operativa de la arquitectura implementada exige mecanismos rigurosos de monitoreo y revisión. La ISO/IEC 27004 facilita el diseño de indicadores de desempeño (KPIs y KRIs), permitiendo cuantificar objetivamente métricas como los porcentajes de disponibilidad del sistema o los tiempos de respuesta ante incidentes. La conformidad y eficiencia de los controles instalados son examinadas a través de auditorías estructuradas bajo los preceptos de la ISO/IEC 27007, mientras que la ISO/IEC 27008 provee las directrices específicas para evaluar la eficacia técnica de dichos controles en la operación real, cerrando así el ciclo de mejora continua del ecosistema tecnológico.

Finalmente, desde una perspectiva directiva, la ISO/IEC 27014 establece el marco de gobernanza corporativa de la seguridad de la información. Esta norma asegura que la gestión de riesgos y la toma de decisiones, tales como la determinación del apetito de riesgo, se alineen indisolublemente con los objetivos estratégicos y misionales de la organización pública. Para materializar estas decisiones en un entorno donde los fondos públicos exigen trazabilidad y eficiencia, el estándar ISO/IEC TR 27016 aporta el modelo de valoración económica. A través de métricas financieras como el retorno de la inversión en seguridad (ROSI), esta norma permite a la alta gerencia justificar económicamente los recursos destinados a la implementación de controles y planes de mitigación, demostrando el

equilibrio racional entre el costo de la protección técnica y el valor estratégico de salvaguardar los servicios digitales del municipio.

4. Análisis de Gobierno, Riesgo y Cumplimiento (GRC)

El enfoque de Gobierno, Riesgo y Cumplimiento (GRC) constituye el eje articulador de la gestión de seguridad en la Empresa Municipal de Servicios Ciudadanos (EMSC), permitiendo que la toma de decisiones trascienda el ámbito puramente técnico para integrarse en la estrategia institucional. Bajo esta metodología, cada matriz de riesgo desarrollada debe responder a tres interrogantes fundamentales que garantizan la integridad del modelo: la identificación de quién posee la autoridad de decisión (Gobierno), la determinación precisa del objeto de gestión (Riesgo) y la vinculación con el marco normativo o legal vigente (Cumplimiento).

En el componente de Gobierno, se formaliza la estructura de responsabilidad estratégica y operativa necesaria para el tratamiento de los riesgos. Esto implica la definición de funciones críticas para la alta dirección, la gerencia de tecnología (CIO), el responsable de seguridad (CISO) y las unidades de auditoría. Estas figuras tienen la facultad y obligación de aprobar controles, supervisar el avance de los planes de mitigación y, fundamentalmente, autorizar la aceptación de riesgos residuales cuando los niveles de exposición se encuentran dentro del apetito de riesgo institucional. Esta estructura asegura que la resiliencia operativa de la plataforma transaccional sea una prioridad de nivel ejecutivo y no únicamente un requerimiento del área de soporte técnico.

El componente de Riesgo se orienta a la gestión táctica de los activos críticos que sostienen los servicios ciudadanos, tales como las bases de datos, los servidores de recaudación, las credenciales de acceso y las integraciones con el sistema bancario. A través del análisis de riesgos, se identifican y priorizan eventos —desde ataques de ransomware hasta fallos en el proveedor de nube— basándose en su probabilidad de ocurrencia e impacto operativo. Este enfoque permite optimizar la asignación de recursos hacia las amenazas que representan el mayor peligro para la continuidad de los trámites municipales y la integridad de los datos financieros.

Finalmente, el componente de Cumplimiento asegura que cada control y acción de mitigación esté anclado a un marco regulatorio exigible. Para la EMSC, esto se fundamenta en el cumplimiento del Acuerdo A-028-2021 y la adopción de la familia de normas ISO/IEC

27000. No obstante, el cumplimiento se extiende hacia principios legales de protección de datos personales, leyes de transparencia administrativa y normativas de control interno gubernamental. Esta integración garantiza que la seguridad de la información no solo sea eficiente desde el punto de vista técnico, sino también legalmente sólida y alineada con la responsabilidad institucional ante los ciudadanos y los entes fiscalizadores.

4.1. Síntesis del Análisis GRC Aplicado

La siguiente tabla resume la aplicación del cuestionario GRC sobre los riesgos críticos identificados para el Data Center híbrido de la institución:

Riesgo Identificado	Gobierno: ¿Quién decide?	Riesgo: ¿Qué se gestiona?	Cumplimiento: ¿Qué norma aplica?
Indisponibilidad del Data Center	CIO / Comité de Riesgos	Continuidad de los servicios de recaudación municipal.	Acuerdo A-028-2021 / ISO 27002 Cláusula 8.13
Secuestro de Información (Ransomware)	CISO / Gerencia General	Integridad y confidencialidad de datos financieros PII.	ISO 27005 / Código Penal (Ciberdelitos)
Fuga de Datos Ciudadanos (PII)	Concejo Municipal / CISO	Privacidad y protección de información sensible.	ISO 27018 / Ley de Acceso a la Información

No solo nos aseguramos de mitigar amenazas, sino de hacerlo bajo un esquema de rendición de cuentas, eficiencia presupuestaria y estricto apego a la legalidad.

Conclusiones

A partir del análisis del ecosistema tecnológico y operativo de la Empresa Municipal de Servicios Ciudadanos (EMSC), se concluye de manera categórica que la institución requiere una gestión de riesgos estructurada, rigurosa y alineada con estándares internacionales. La criticidad intrínseca de su plataforma transaccional, el tratamiento constante de datos financieros y personales (PII), y su dependencia de una arquitectura de nube híbrida interconectada con entidades externas, hacen inviable sostener modelos de seguridad ad hoc. Si bien el uso de las matrices establecidas por el Acuerdo A-028-2021 proporciona un ordenamiento inicial válido, el verdadero rigor técnico y valor analítico se alcanza únicamente mediante la integración sistemática con la familia de normas ISO/IEC 27000.

Desde una perspectiva operativa, es imperativo que la EMSC adopte un enfoque de Resiliencia integral. La entidad debe transicionar de una postura tradicional y reactiva frente a incidentes cibernéticos hacia un modelo proactivo que garantice la continuidad del negocio. Esto implica priorizar de manera urgente la redundancia física en los subsistemas de soporte del Data Center institucional y robustecer las estrategias de seguridad perimetral y lógica en la nube, operando invariablemente bajo el esquema de responsabilidad compartida con los proveedores de servicios. La protección del servicio ciudadano no permite improvisaciones en el diseño de su infraestructura subyacente.

En el ámbito administrativo, la Institucionalización del GRC (Gobierno, Riesgo y Cumplimiento) se presenta como un factor crítico de éxito. El análisis demostró que vincular cada amenaza tecnológica con una instancia de decisión específica, un activo concreto y una normativa aplicable (como SINACIG y las leyes de privacidad), transforma la seguridad de la información, llevándola de un requerimiento técnico a una estrategia de supervivencia institucional. En el sector público, el éxito de la mitigación de riesgos depende directamente de la asignación formal de responsables estratégicos y de la capacidad de demostrar gobernanza continua sobre los procesos tecnológicos y la protección de los datos.

Finalmente, la sostenibilidad del modelo propuesto recae en la Justificación Financiera de las inversiones requeridas. En una organización gubernamental sometida a estricto escrutinio presupuestario, identificar vulnerabilidades es insuficiente; es mandatorio valorar económicamente el riesgo. La aplicación estricta de la norma ISO/IEC TR 27016 es crítica para evidenciar ante el Concejo Municipal que las inversiones en tecnologías

avanzadas, como plataformas XDR o la modernización de los sistemas UPS, representan una fracción mínima del impacto financiero y reputacional que conllevaría una interrupción total del servicio de recaudación o una brecha masiva de datos. La ciberseguridad, gestionada bajo este marco, se consolida como un habilitador del cumplimiento legal y un escudo protector del patrimonio municipal, no como un gasto operativo discrecional.